



Cookie Monster



Bối cảnh (Context)

Một cửa hàng bánh ngọt trực tuyến có tên "Sweet Treats" đang phát hành một loại bánh quy giới hạn. Để được mua loại bánh này, bạn phải là thành viên hạng VIP. Khi người dùng đăng nhập vào hệ thống, họ nhận được một chiếc "Cookie" (trên trình duyệt) lưu trữ trạng thái phiên làm việc.

Quản trị viên đã quá tự tin vào khả năng mã hóa tự chế của mình và tin rằng không một khách hàng bình thường nào có thể can thiệp được vào nội dung của chiếc Cookie đó để tự phong mình làm VIP.



Mục tiêu (Objective)

- **Nhiệm vụ:** Từ một tài khoản khách thông thường, hãy tìm cách trở thành thành viên VIP (hoặc Admin) để xem được công thức làm bánh bí mật (Flag).
- **Vấn đề / Lỗi hổng:** Cơ chế quản lý phiên đăng nhập sử dụng **Insecure Cookie**. Nội dung Cookie chứa trạng thái phân quyền (ví dụ `user_role=guest`) nhưng lại không được ký (sign) bằng mã Hash an toàn hoặc chỉ được mã hóa/encode rất hời hợt (như Base64).
- **Flag:** Đổi Cookie thành công và truy cập vào trang quản trị để nhận Flag.



Gợi ý (Hints)

- Hãy mở Developer Tools của trình duyệt (F12) -> tab Application / Storage để xem các Cookies đang được lưu.
- Thử đưa giá trị của Cookie vào một công cụ giải mã (như Base64 Decoder) xem nó chứa gì.
- Có thể thay đổi nội dung đó và encode ngược lại không?